

# Developer Report

Acunetix Security Audit

2026-03-13

Generated by Acunetix

---

# Scan of 10.28.12.15

## Scan details

|                    |                                  |
|--------------------|----------------------------------|
| Scan information   |                                  |
| Start time         | 2026-03-07T09:51:18.929467+08:00 |
| Start url          | http://10.28.12.15/              |
| Host               | 10.28.12.15                      |
| Scan time          | 194 minutes, 19 seconds          |
| Profile            | Full Scan                        |
| Server information | nginx                            |
| Responsive         | True                             |
| Server OS          | Unknown                          |
| Application build  | 24.10.241106172                  |

## Threat level

### Acunetix Threat Level 2

One or more medium-severity type vulnerabilities have been discovered by the scanner. You should investigate each of these vulnerabilities to ensure they will not escalate to more severe problems.

## Alerts distribution

|                                                                                                 |   |
|-------------------------------------------------------------------------------------------------|---|
| Total alerts found                                                                              | 8 |
|  Critical      | 0 |
|  High          | 0 |
|  Medium        | 2 |
|  Low           | 4 |
|  Informational | 2 |

Alerts summary

 Insecure HTTP Usage

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| Classification             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Changed<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-16                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

 SSL/TLS Not Implemented

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |           |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N<br>Base Score: 5.1<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: Low<br>Integrity Impact to the Vulnerable System: Low<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N<br>Base Score: 5.4<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Unchanged<br>Confidentiality Impact: Low<br>Integrity Impact: Low<br>Availability Impact: None                                                                                                                                                                                                                                           |           |
| CVSS2                      | Base Score: 5.8<br>Access Vector: Network_accessible<br>Access Complexity: Medium<br>Authentication: None<br>Confidentiality Impact: Partial<br>Integrity Impact: Partial<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined              |           |
| CWE                        | CWE-319                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | 1         |


**[Possible] Internal IP Address Disclosure**

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |           |
|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 6.9<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: None<br>Confidentiality Impact to the Vulnerable System: Low<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N<br>Base Score: 5.3<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: None<br>Scope: Unchanged<br>Confidentiality Impact: Low<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 5.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: Partial<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                   |           |
| CWE                        | CWE-200                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 1         |

⌵ Cookies Not Marked as HttpOnly

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Unchanged<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                           |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-1004                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

Programming Error Messages

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |           |
|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 6.9<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: None<br>Confidentiality Impact to the Vulnerable System: Low<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N<br>Base Score: 5.3<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: None<br>Scope: Unchanged<br>Confidentiality Impact: Low<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 5.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: Partial<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                   |           |
| CWE                        | CWE-209                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 1         |

Sensitive pages could be cached

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |           |
|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 6.9<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: None<br>Confidentiality Impact to the Vulnerable System: Low<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N<br>Base Score: 5.3<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: None<br>Scope: Unchanged<br>Confidentiality Impact: Low<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 5.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: Partial<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                   |           |
| CWE                        | CWE-200                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | 1         |

 **Content Security Policy (CSP) Not Implemented**

|                |
|----------------|
| Classification |
|----------------|



|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Changed<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-1021                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

 **Permissions-Policy header not implemented**

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Changed<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-1021                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

Alerts details

 Insecure HTTP Usage

|                    |                              |
|--------------------|------------------------------|
| Severity           | Medium                       |
| Reported by module | /target/http_redirections.js |

Description

It was detected that your web application uses HTTP protocol, but doesn't automatically redirect users to HTTPS.

Impact

In some circumstances, it could be used for a man-in-the-middle (MitM) attack

Recommendation

It's recommended to implement best practices of HTTP Redirection into your web application. Consult web references for more information

References

[HTTP Redirections](https://infosec.mozilla.org/guidelines/web_security#http-redirections) ([https://infosec.mozilla.org/guidelines/web\\_security#http-redirections](https://infosec.mozilla.org/guidelines/web_security#http-redirections))

Affected items

| Web Server                                                                                                                  |
|-----------------------------------------------------------------------------------------------------------------------------|
| Details                                                                                                                     |
| Request headers                                                                                                             |
| GET / HTTP/1.1                                                                                                              |
| Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8                                                     |
| Accept-Encoding: gzip,deflate,br                                                                                            |
| User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 |
| Host: 10.28.12.15                                                                                                           |
| Connection: Keep-alive                                                                                                      |

 SSL/TLS Not Implemented

|                    |                  |
|--------------------|------------------|
| Severity           | Medium           |
| Reported by module | /RPA/no_https.js |

Description

This scan target was connected to over an unencrypted connection. A potential attacker can intercept and modify data sent and received from this site.

Impact

Possible information disclosure.

Recommendation

The site should send and receive data over a secure (HTTPS) connection.

References

[SSL/TLS Not Implemented | Invicti](https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/ssltls-not-implemented/) (https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/ssltls-not-implemented/)

Affected items

Web Server

Verified vulnerability

Details

Request headers

GET /xgszp-boot/xgsHome/xgsHome/listForHome?newsType=homeImages&pageNo=1&pageSize=10&\_t=1772848301759 HTTP/1.1

Host: 10.28.12.15

accept: application/json, text/plain, \*/\*

accept-language: en-US

x-sign: C417361CE7762B2284126BF570F041B1

x-timestamp: 1772848301880

x-version: v3

Referer: http://10.28.12.15/home/index

Accept-Encoding: gzip, deflate, br

Connection: keep-alive

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

⌵ [Possible] Internal IP Address Disclosure

|                    |                          |
|--------------------|--------------------------|
| Severity           | Low                      |
| Reported by module | /httpdata/text_search.js |

Description

One or more strings matching an internal IPv4 address were found. These IPv4 addresses may disclose information about the IP addressing scheme of the internal network. This information can be used to conduct further attacks.

The significance of this finding should be confirmed manually.

Impact

Possible sensitive information disclosure.

Recommendation

Prevent this information from being displayed to the user.

References

[Internal IP Address Disclosure | Invicti](https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/internal-ip-address-disclosure/) (https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/internal-ip-address-disclosure/).

Affected items

**Web Server**

Details

Pages with internal IPs:

- http://10.28.12.15/js/**10.22.82.48**
- http://10.28.12.15/js/index-DLtD-Rbd.js**10.22.82.48**

Request headers

GET /js/index-DLtD-Rbd.js HTTP/1.1

Referer: http://10.28.12.15/clientaccesspolicy.xml

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.15

Connection: Keep-alive

Cookies Not Marked as HttpOnly

|                    |                                 |
|--------------------|---------------------------------|
| Severity           | Low                             |
| Reported by module | /RPA/Cookie_Without_HttpOnly.js |

Description

One or more cookies don't have the HttpOnly flag set. When a cookie is set with the HttpOnly flag, it instructs the browser that the cookie can only be accessed by the server and not by client-side scripts. This is an important security protection for session cookies.

Impact

Cookies can be accessed by client-side scripts.

Recommendation

If possible, you should set the HttpOnly flag for these cookies.

References

[Cookie Not Marked as HttpOnly | Invicti](https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/cookie-not-marked-as-httponly/) (<https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/cookie-not-marked-as-httponly/>).

Affected items

| Web Server             |
|------------------------|
| Verified vulnerability |
| Details                |

## Cookies without HttpOnly flag set:

- <http://10.28.12.15/xgszp-boot/sys/>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgsTalentpool/xgsTalentpool/add>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgsTalentpool/xgsTalentpool/>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgsTalentpool/>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgszp-boot/online/cgform/api/>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgszp-boot/>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgszp-boot/resume/>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgszp-boot/online/>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgszp-boot/online/cgform/>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsMyresume/>

```
Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202
```

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/xgsContactUs/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInviteToInterview/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/sys/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeBSH/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/xgsInterview/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsMyresume/xgsMyresume/>

Set-Cookie: rememberMe=deleteMe; Path=/xgszp-boot; Max-Age=0; Expires=Fri, 06-Mar-202



## Request headers

GET /xgszp-boot/sys/ HTTP/1.1

Referer: http://10.28.12.15/xgszp-boot/sys/

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.15

Connection: Keep-alive

## ▼ Programming Error Messages

|                    |                                         |
|--------------------|-----------------------------------------|
| Severity           | Low                                     |
| Reported by module | /Scripts/PerScheme/Error_Message.script |

### Description

This alert requires manual confirmation

Acunetix found one or more error/warning messages. Application error or warning messages may expose sensitive information about an application's internal workings to an attacker. These messages may also contain the location of the file that produced an unhandled exception. Consult the 'Attack details' section for more information about the affected page(s).

### Impact

Error messages may disclose sensitive information which can be used to escalate attacks.

### Recommendation

Verify that these page(s) are disclosing error or warning messages and properly configure the application to log errors to a file instead of displaying the error to the user.

### References

[PHP Runtime Configuration](https://www.php.net/manual/en/errorfunc.configuration.php#ini.display-errors) (https://www.php.net/manual/en/errorfunc.configuration.php#ini.display-errors)  
[Improper Error Handling](https://www.owasp.org/index.php/Improper_Error_Handling) (https://www.owasp.org/index.php/Improper\_Error\_Handling)

### Affected items

#### Web Server

Details

## Application error messages:

- <http://10.28.12.15/xgszp-boot/sys/randomImage/1629428467008>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgsJournalism/xgsJournalism/queryById>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgsJournalism/xgsJournalism/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeBase/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeBase/listMine>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeBase/listMyResume>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeBSH/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsMyresume/xgsMyresume/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)

- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/xgsTalentpool/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/listMine>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInviteToInterview/xgsInviteToInterview/myInterviewList>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsJournalism/xgsJournalism/listForHomeNews>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)

- <http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/listMine>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/listForHome>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsUserResumeFile/list>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)
- <http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/fileList>  
org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)  
org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)  
org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)  
org.apache.coyote.AbstractProtocol\$ConnectionHandler.process(AbstractProtocol.java:939)  
org.apache.tomcat.util.net.NioEndpoint\$SocketProcessor.doRun(NioEndpoint.java:1831)  
org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)  
org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)  
org.apache.tomcat.util.threads.ThreadPoolExecutor\$Worker.run(ThreadPoolExecutor.java:491)  
org.apache.tomcat.util.threads.TaskThread\$WrappingRunnable.run(TaskThread.java:63)  
java.lang.Thread.run(Thread.java:750)

- `http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInviteToInterview/xgsInviteToInterview/list`  
`org.apache.coyote.http11.Http11InputBuffer.parseRequestLine(Http11InputBuffer.java:477)`  
`org.apache.coyote.http11.Http11Processor.service(Http11Processor.java:271)`  
`org.apache.coyote.AbstractProcessorLight.process(AbstractProcessorLight.java:63)`  
`org.apache.coyote.AbstractProtocol$ConnectionHandler.process(AbstractProtocol.java:939)`  
`org.apache.tomcat.util.net.NioEndpoint$SocketProcessor.doRun(NioEndpoint.java:1831)`  
`org.apache.tomcat.util.net.SocketProcessorBase.run(SocketProcessorBase.java:52)`  
`org.apache.tomcat.util.threads.ThreadPoolExecutor.runWorker(ThreadPoolExecutor.java:973)`  
`org.apache.tomcat.util.threads.ThreadPoolExecutor$Worker.run(ThreadPoolExecutor.java:491)`  
`org.apache.tomcat.util.threads.TaskThread$WrappingRunnable.run(TaskThread.java:63)`  
`java.lang.Thread.run(Thread.java:750)`

## Request headers

GET /xgszp-boot/sys/randomImage/1629428467008?\_t=12345'"\"");|]\*%00{%0d%0a<%00>%bf%27'💡  
 HTTP/1.1

Referer: http://10.28.12.15/

Accept: application/json, text/plain, \*/\*

x-sign: E19D6243CB1945AB4F7202A1B00F77D5

x-timestamp: 1772848309001

x-version: v3

Accept-Encoding: gzip, deflate, br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.15

Connection: Keep-alive

## ✓ Sensitive pages could be cached

|                    |                                  |
|--------------------|----------------------------------|
| Severity           | Low                              |
| Reported by module | /RPA/Cacheable_Sensitive_Page.js |

## Description

One or more pages contain possible sensitive information (e.g. a password parameter) and could be potentially cached. Even in secure SSL channels sensitive data could be stored by intermediary proxies and SSL terminators. To prevent this, a Cache-Control header should be specified.

## Impact

Possible sensitive information disclosure.

## Recommendation

Prevent caching by adding "Cache Control: No-store" and "Pragma: no-cache" to the HTTP response header.

References

[OWASP - Caching of Sensitive Information](https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/04-Authentication_Testing/06-Testing_for_Browser_Cache_Weaknesses) (https://owasp.org/www-project-web-security-testing-guide/latest/4-Web\_Application\_Security\_Testing/04-Authentication\_Testing/06-Testing\_for\_Browser\_Cache\_Weaknesses)  
[MDN Web Docs - Cache-Control](https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control) (https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control)  
[CWE-524: Use of Cache Containing Sensitive Information](https://cwe.mitre.org/data/definitions/524.html) (https://cwe.mitre.org/data/definitions/524.html)

Affected items

| Web Server                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Details                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| List of pages that could be cached: <ul style="list-style-type: none"><li>• http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/listMine?applyResult=DefaultStringValue&amp;applyStatus=DefaultStringValue&amp;approvalNode=DefaultStringValue&amp;approvalStat<br/>us=DefaultStringValue&amp;createBy=DefaultStringValue&amp;createTime=01/01/1967&amp;deleted=DefaultStringValue&amp;id=1&amp;i<br/>nterviewDate=01/01/1967&amp;interviewInformation=DefaultStringValue&amp;interviewStatus=DefaultStringValue&amp;inviteStat<br/>us=DefaultStringValue&amp;mark=DefaultStringValue&amp;positionDept=DefaultStringValue&amp;positionId=DefaultStringValue&amp;<br/>positionName=tMtFQiRt&amp;positionType=DefaultStringValue&amp;resumeFile=DefaultStringValue&amp;resumeld=DefaultStrin<br/>gValue&amp;resumeName=tMtFQiRt&amp;status=DefaultStringValue&amp;sysOrgCode=94102&amp;tagIds=17&amp;tenantId=1&amp;updateB<br/>y=01/01/1967&amp;updateTime=01/01/1967&amp;userId=tMtFQiRt&amp;userName=tMtFQiRt&amp;pageNo=4111111111111111&amp;page<br/>Size=20</li><li>• http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/listMine?applyResult=DefaultStringValue&amp;applyStatus=DefaultStringValue&amp;approvalNode=DefaultStringValue&amp;approvalStat<br/>us=DefaultStringValue&amp;createBy=DefaultStringValue&amp;createTime=01/01/1967&amp;deleted=DefaultStringValue&amp;id=1&amp;i<br/>nterviewDate=01/01/1967&amp;interviewInformation=DefaultStringValue&amp;interviewStatus=DefaultStringValue&amp;inviteStat<br/>us=DefaultStringValue&amp;mark=DefaultStringValue&amp;positionDept=DefaultStringValue&amp;positionId=DefaultStringValue&amp;<br/>positionName=tMtFQiRt&amp;positionType=DefaultStringValue&amp;resumeFile=DefaultStringValue&amp;resumeld=DefaultStrin<br/>gValue&amp;resumeName=tMtFQiRt&amp;status=DefaultStringValue&amp;sysOrgCode=94102&amp;tagIds=17&amp;tenantId=1&amp;updateB<br/>y=01/01/1967&amp;updateTime=01/01/1967&amp;userId=tMtFQiRt&amp;userName=tMtFQiRt&amp;pageNo=4111111111111111&amp;page<br/>Size=20</li><li>• http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/list?applyResult=DefaultStringValue&amp;applyStatus=DefaultStringValue&amp;approvalNode=DefaultStringValue&amp;approvalStat<br/>us=DefaultStringValue&amp;createBy=DefaultStringValue&amp;createTime=01/01/1967&amp;deleted=DefaultStringValue&amp;id=1&amp;i<br/>nterviewDate=01/01/1967&amp;interviewInformation=DefaultStringValue&amp;interviewStatus=DefaultStringValue&amp;inviteStat<br/>us=DefaultStringValue&amp;mark=DefaultStringValue&amp;positionDept=DefaultStringValue&amp;positionId=DefaultStringValue&amp;<br/>positionName=tMtFQiRt&amp;positionType=DefaultStringValue&amp;resumeFile=DefaultStringValue&amp;resumeld=DefaultStrin<br/>gValue&amp;resumeName=tMtFQiRt&amp;status=DefaultStringValue&amp;sysOrgCode=94102&amp;tagIds=17&amp;tenantId=1&amp;updateB<br/>y=01/01/1967&amp;updateTime=01/01/1967&amp;userId=tMtFQiRt&amp;userName=tMtFQiRt&amp;pageNo=4111111111111111&amp;page<br/>Size=20</li><li>• http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/list?applyResult=DefaultStringValue&amp;applyStatus=DefaultStringValue&amp;approvalNode=DefaultStringValue&amp;approvalStat<br/>us=DefaultStringValue&amp;createBy=DefaultStringValue&amp;createTime=01/01/1967&amp;deleted=DefaultStringValue&amp;id=1&amp;i<br/>nterviewDate=01/01/1967&amp;interviewInformation=DefaultStringValue&amp;interviewStatus=DefaultStringValue&amp;inviteStat<br/>us=DefaultStringValue&amp;mark=DefaultStringValue&amp;positionDept=DefaultStringValue&amp;positionId=DefaultStringValue&amp;<br/>positionName=tMtFQiRt&amp;positionType=DefaultStringValue&amp;resumeFile=DefaultStringValue&amp;resumeld=DefaultStrin<br/>gValue&amp;resumeName=tMtFQiRt&amp;status=DefaultStringValue&amp;sysOrgCode=94102&amp;tagIds=17&amp;tenantId=1&amp;updateB<br/>y=01/01/1967&amp;updateTime=01/01/1967&amp;userId=tMtFQiRt&amp;userName=tMtFQiRt&amp;pageNo=4111111111111111&amp;page<br/>Size=20</li><li>• http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/listMine?createBy=DefaultStringValue&amp;createTime=01/01/1967&amp;hasApplied=DefaultStringValue&amp;id=1&amp;positionCount=Defau<br/>ltStringValue&amp;positionDept=DefaultStringValue&amp;positionId=DefaultStringValue&amp;positionKtz=DefaultStringValue&amp;pos<br/>itionName=tMtFQiRt&amp;sysOrgCode=94102&amp;updateBy=01/01/1967&amp;updateTime=01/01/1967&amp;userId=tMtFQiRt&amp;use<br/>rName=tMtFQiRt&amp;pageNo=4111111111111111&amp;pageSize=20</li><li>• http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/list?createBy=DefaultStringValue&amp;createTime=01/01/1967&amp;hasApplied=DefaultStringValue&amp;id=1&amp;positionCount=Defau<br/>ltStringValue&amp;positionDept=DefaultStringValue&amp;positionId=DefaultStringValue&amp;positionKtz=DefaultStringValue&amp;pos<br/>itionName=tMtFQiRt&amp;sysOrgCode=94102&amp;updateBy=01/01/1967&amp;updateTime=01/01/1967&amp;userId=tMtFQiRt&amp;use<br/>rName=tMtFQiRt&amp;pageNo=4111111111111111&amp;pageSize=20</li></ul> |

## Request headers

```
GET /xgszp-boot/xgszp-boot/positions/xgsPositionApply2/listMine?
applyResult=DefaultStringValue&applyStatus=DefaultStringValue&approvalNode=DefaultStringV
alue&approvalStatus=DefaultStringValue&createBy=DefaultStringValue&createTime=01/01/1967&
deleted=DefaultStringValue&id=1&interviewDate=01/01/1967&interviewInformation=DefaultStri
ngValue&interviewStatus=DefaultStringValue&inviteStatus=DefaultStringValue&mark=DefaultSt
ringValue&positionDept=DefaultStringValue&positionId=DefaultStringValue&positionName=tMtF
QiRt&positionType=DefaultStringValue&resumeFile=DefaultStringValue&resumeId=DefaultString
Value&resumeName=tMtFQiRt&status=DefaultStringValue&sysOrgCode=94102&tagIds=17&tenantId=1
&updateBy=01/01/1967&updateTime=01/01/1967&userId=tMtFQiRt&userName=tMtFQiRt&pageNo=41111
111111111111&pageSize=20 HTTP/1.1
```

Referer: http://10.28.12.15/xgszp-boot/v2/api-docs

Content-Type: application/json

Accept: application/json;q=0.9, application/xml;q=0.8

X-Access-Token: 20

Accept-Encoding: gzip, deflate, br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.15

Connection: Keep-alive

## Content Security Policy (CSP) Not Implemented

|                    |                                  |
|--------------------|----------------------------------|
| Severity           | Informational                    |
| Reported by module | /httpdata/CSP_not_implemented.js |

### Description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks.

Content Security Policy (CSP) can be implemented by adding a **Content-Security-Policy** header. The value of this header is a string containing the policy directives describing your Content Security Policy. To implement CSP, you should define lists of allowed origins for the all of the types of resources that your site utilizes. For example, if you have a simple site that needs to load scripts, stylesheets, and images hosted locally, as well as from the jQuery library from their CDN, the CSP header could look like the following:

```
Content-Security-Policy:
  default-src 'self';
  script-src 'self' https://code.jquery.com;
```

It was detected that your web application doesn't implement Content Security Policy (CSP) as the CSP header is missing from the response. It's recommended to implement Content Security Policy (CSP) into your web application.



Impact

CSP can be used to prevent and/or mitigate attacks that involve content/code injection, such as cross-site scripting/XSS attacks, attacks that require embedding a malicious resource, attacks that involve malicious use of iframes, such as clickjacking attacks, and others.

Recommendation

It's recommended to implement Content Security Policy (CSP) into your web application. Configuring Content Security Policy involves adding the **Content-Security-Policy** HTTP header to a web page and giving it values to control resources the user agent is allowed to load for that page.

References

[Content Security Policy \(CSP\)](https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP) (https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP)  
[Implementing Content Security Policy](https://hacks.mozilla.org/2016/02/implementing-content-security-policy/) (https://hacks.mozilla.org/2016/02/implementing-content-security-policy/)

Affected items

| Web Server |
|------------|
| Details    |

#### Paths without CSP header:

- <http://10.28.12.15/clientaccesspolicy.xml>
- <http://10.28.12.15/login>
- <http://10.28.12.15/xgszp-boot/xgsHome/>
- <http://10.28.12.15/xgszp-boot/xgsJournalism/xgsJournalism/>
- <http://10.28.12.15/crossdomain.xml>
- <http://10.28.12.15/xgszp-boot/xgsJournalism/>
- <http://10.28.12.15/>
- <http://10.28.12.15/xgszp-boot/>
- <http://10.28.12.15/xgszp-boot/xgsHome/xgsHome/>
- <http://10.28.12.15/home/contactUs>
- <http://10.28.12.15/home/>
- <http://10.28.12.15/home/news>
- <http://10.28.12.15/home/positions>
- <http://10.28.12.15/home/ygqk>
- <http://10.28.12.15/xgszp-boot/swagger-resources/configuration/>
- [http://10.28.12.15/assets/%23clip-Web\\_1920\\_1](http://10.28.12.15/assets/%23clip-Web_1920_1)
- <http://10.28.12.15/assets/%23clip-path>
- <http://10.28.12.15/assets/%23linear-gradient>
- <http://10.28.12.15/xgszp-boot/webjars/fonts/>
- <http://10.28.12.15/xgszp-boot/webjars/img/>
- <http://10.28.12.15/xgszp-boot/webjars/>

#### Request headers

```
GET /clientaccesspolicy.xml HTTP/1.1

Referer: http://10.28.12.15/

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.15

Connection: Keep-alive
```

 **Permissions-Policy header not implemented**

|                    |                                 |
|--------------------|---------------------------------|
| Severity           | Informational                   |
| Reported by module | /httpdata/permissions_policy.js |

**Description**

The Permissions-Policy header allows developers to selectively enable and disable use of various browser features and APIs.

**Impact**

**Recommendation**

**References**

[Permissions-Policy / Feature-Policy \(MDN\)](https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy) (https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy)  
[Permissions Policy \(W3C\)](https://www.w3.org/TR/permissions-policy-1/) (https://www.w3.org/TR/permissions-policy-1/)

**Affected items**

|                   |
|-------------------|
| <b>Web Server</b> |
| Details           |

#### Locations without Permissions-Policy header:

- <http://10.28.12.15/xgszp-boot/sys/>
- <http://10.28.12.15/clientaccesspolicy.xml>
- <http://10.28.12.15/login>
- <http://10.28.12.15/xgszp-boot/xgsHome/>
- <http://10.28.12.15/xgszp-boot/xgsJournalism/xgsJournalism/>
- <http://10.28.12.15/crossdomain.xml>
- <http://10.28.12.15/assets/>
- <http://10.28.12.15/xgszp-boot/xgsJournalism/>
- <http://10.28.12.15/>
- <http://10.28.12.15/xgszp-boot/>
- <http://10.28.12.15/xgszp-boot/xgsHome/xgsHome/>
- <http://10.28.12.15/home/contactUs>
- <http://10.28.12.15/resource/img/>
- <http://10.28.12.15/home/>
- <http://10.28.12.15/resource/>
- <http://10.28.12.15/home/news>
- <http://10.28.12.15/home/positions>
- <http://10.28.12.15/home/ygqk>
- <http://10.28.12.15/xgszp-boot/xgsTalentpool/xgsTalentpool/add>
- <http://10.28.12.15/xgszp-boot/xgsTalentpool/xgsTalentpool/>
- <http://10.28.12.15/xgszp-boot/swagger-resources/configuration/>

#### Request headers

GET /xgszp-boot/sys/ HTTP/1.1

Referer: <http://10.28.12.15/xgszp-boot/sys/>

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.15

Connection: Keep-alive

## Scanned items (coverage report)

---

<http://10.28.12.15/>

[http://10.28.12.15/\\_app.config.js](http://10.28.12.15/_app.config.js)  
<http://10.28.12.15/assets/>  
<http://10.28.12.15/assets/#clip-path>  
[http://10.28.12.15/assets/#clip-Web\\_1920\\_1](http://10.28.12.15/assets/#clip-Web_1920_1)  
<http://10.28.12.15/assets/#linear-gradient>  
<http://10.28.12.15/assets/app-antd-dark-theme-style.e3b0c442.css>  
<http://10.28.12.15/assets/app-theme-style.e3b0c442.css>  
<http://10.28.12.15/assets/BasicModal-ByeTDAzn.css>  
<http://10.28.12.15/assets/CaptchaModal-T3MvbfZJ.css>  
<http://10.28.12.15/assets/componentMap-CfXhrpGb.css>  
<http://10.28.12.15/assets/EasyCronInput-BLbXuoBB.css>  
<http://10.28.12.15/assets/home-CMeLbwbP.css>  
<http://10.28.12.15/assets/idea-C3eFBO7g.css>  
<http://10.28.12.15/assets/index-6eBWgmf3.css>  
<http://10.28.12.15/assets/index-BB9COjV3.css>  
<http://10.28.12.15/assets/index-Bqt7Apke.css>  
[http://10.28.12.15/assets/index-C\\_kRjyES.css](http://10.28.12.15/assets/index-C_kRjyES.css)  
<http://10.28.12.15/assets/index-CCoUyDAE.css>  
<http://10.28.12.15/assets/index-D8VMPIi6.css>  
<http://10.28.12.15/assets/index-DTCEk8S9.css>  
<http://10.28.12.15/assets/index-Dwp3Sezh.css>  
<http://10.28.12.15/assets/index-zj-Vfn3Q.css>  
<http://10.28.12.15/assets/JAddInput-4Itl5-IO.css>  
<http://10.28.12.15/assets/JCodeEditor-DKSVAhFE.css>  
<http://10.28.12.15/assets/JImageUpload-Q90hb5Z6.css>  
<http://10.28.12.15/assets/JPopup-BuD3XYrw.css>  
<http://10.28.12.15/assets/JSelectBiz-CeZTrWEr.css>  
[http://10.28.12.15/assets/JSelectDept-BE36GjR\\_.css](http://10.28.12.15/assets/JSelectDept-BE36GjR_.css)  
<http://10.28.12.15/assets/JSelectUser-CFwmpWe5.css>  
<http://10.28.12.15/assets/JUpload-CTjYYrtW.css>  
<http://10.28.12.15/assets/JVxeDepartSelectCell-Dj7n51ZX.css>  
[http://10.28.12.15/assets/JVxeImageCell-C8g9jCj\\_.css](http://10.28.12.15/assets/JVxeImageCell-C8g9jCj_.css)  
<http://10.28.12.15/assets/JVxeUserSelectCell-DvQTNLcn.css>  
<http://10.28.12.15/assets/MiniCodeLogin-BCWk7eRg.css>  
[http://10.28.12.15/assets/MiniForgotpad-BQc\\_3Wyx.css](http://10.28.12.15/assets/MiniForgotpad-BQc_3Wyx.css)  
<http://10.28.12.15/assets/MiniLogin-CxJIO1aN.css>  
<http://10.28.12.15/assets/MiniRegister-bjNHdGxj.css>  
<http://10.28.12.15/assets/ModalHeader-CLCbovMP.css>  
<http://10.28.12.15/assets/newsDetail-BwCzAM1Z.css>  
<http://10.28.12.15/assets/useContextMenu-DRJLeHo9.css>  
<http://10.28.12.15/assets/useForm-DGLoY8nv.css>  
[http://10.28.12.15/assets/vue-DyVx2\\_Fd.css](http://10.28.12.15/assets/vue-DyVx2_Fd.css)  
<http://10.28.12.15/clientaccesspolicy.xml>  
<http://10.28.12.15/crossdomain.xml>  
<http://10.28.12.15/home/>  
<http://10.28.12.15/home/contactUs>  
<http://10.28.12.15/home/index>  
<http://10.28.12.15/home/news>  
<http://10.28.12.15/home/positions>  
<http://10.28.12.15/home/ygqk>  
<http://10.28.12.15/js/>  
<http://10.28.12.15/js/antd-vue-vendor-pKq8eB2t.js>  
<http://10.28.12.15/js/areaDataUtil-PgwwkN7b.js>  
<http://10.28.12.15/js/base64Conver-24EVOS6V.js>  
<http://10.28.12.15/js/BasicModal-ZwRSsb7s.js>  
<http://10.28.12.15/js/bem-nvWdt0HR.js>  
<http://10.28.12.15/js/CaptchaModal-CroHfEpL.js>  
<http://10.28.12.15/js/checkcode-BFTITB0q.js>

<http://10.28.12.15/js/componentMap-By4Kafjw.js>  
<http://10.28.12.15/js/depart.api-Cvm-97Bc.js>  
<http://10.28.12.15/js/download-ChJ54AMK.js>  
<http://10.28.12.15/js/home-Bw-NdbVC.js>  
[http://10.28.12.15/js/htmlmixed-DxS\\_GiPM.js](http://10.28.12.15/js/htmlmixed-DxS_GiPM.js)  
[http://10.28.12.15/js/icon-success--Tnc\\_yON.js](http://10.28.12.15/js/icon-success--Tnc_yON.js)  
<http://10.28.12.15/js/index-BtriQWND.js>  
<http://10.28.12.15/js/index-ByUnKrsX.js>  
[http://10.28.12.15/js/index-C\\_2-LhW\\_.js](http://10.28.12.15/js/index-C_2-LhW_.js)  
<http://10.28.12.15/js/index-C5atDIjv.js>  
<http://10.28.12.15/js/index-CLU5oOsE.js>  
<http://10.28.12.15/js/index-Ct922EYw.js>  
<http://10.28.12.15/js/index-Cw3oi3Hb.js>  
<http://10.28.12.15/js/index-CZlb4H2L.js>  
<http://10.28.12.15/js/index-DaMZQDne.js>  
<http://10.28.12.15/js/index-DLtD-Rbd.js>  
<http://10.28.12.15/js/index-DnH6H0sb.js>  
<http://10.28.12.15/js/index-DoUry8tO.js>  
<http://10.28.12.15/js/index-Ds8iTx51.js>  
<http://10.28.12.15/js/index-DyKwv5Tv.js>  
[http://10.28.12.15/js/index-w7bCzs0\\_.js](http://10.28.12.15/js/index-w7bCzs0_.js)  
<http://10.28.12.15/js/JAddInput-C9iDolwy.js>  
<http://10.28.12.15/js/JAreaLinkage-2ucTVIAe.js>  
[http://10.28.12.15/js/JCodeEditor-CP\\_wtCzM.js](http://10.28.12.15/js/JCodeEditor-CP_wtCzM.js)  
[http://10.28.12.15/js/jeecg\\_ad\\_text-CEPWyRhD.js](http://10.28.12.15/js/jeecg_ad_text-CEPWyRhD.js)  
<http://10.28.12.15/js/JEllipsis-BYRCvP-S.js>  
<http://10.28.12.15/js/JImageUpload-BWqHM2zh.js>  
<http://10.28.12.15/js/JPopup-Czh7liC4.js>  
<http://10.28.12.15/js/JSelectBiz-rA8tGHyF.js>  
<http://10.28.12.15/js/JSelectDept-Dbyx0nJ3.js>  
[http://10.28.12.15/js/JSelectUser-BJt\\_YQJh.js](http://10.28.12.15/js/JSelectUser-BJt_YQJh.js)  
[http://10.28.12.15/js/JUpload-Bw\\_qjKGU.js](http://10.28.12.15/js/JUpload-Bw_qjKGU.js)  
<http://10.28.12.15/js/JVxeDepartSelectCell-Dyhev008.js>  
[http://10.28.12.15/js/JVxeFileCell-B\\_QUA7U6.js](http://10.28.12.15/js/JVxeFileCell-B_QUA7U6.js)  
<http://10.28.12.15/js/JVxeImageCell-DU21LnVt.js>  
<http://10.28.12.15/js/JVxePopupCell-BTSjt8FO.js>  
<http://10.28.12.15/js/JVxeUserSelectCell-BEP6V2FW.js>  
[http://10.28.12.15/js/MiniForgotpad-Bkk5\\_336.js](http://10.28.12.15/js/MiniForgotpad-Bkk5_336.js)  
[http://10.28.12.15/js/MiniLogin-D1T\\_XrBM.js](http://10.28.12.15/js/MiniLogin-D1T_XrBM.js)  
<http://10.28.12.15/js/ModalHeader-DIRwm611.js>  
<http://10.28.12.15/js/props-CtNNjgXn.js>  
[http://10.28.12.15/js/props-DEZux1\\_h.js](http://10.28.12.15/js/props-DEZux1_h.js)  
<http://10.28.12.15/js/ThirdModal-Bkpmi6D8.js>  
<http://10.28.12.15/js/useContextMenu-D3839NBH.js>  
<http://10.28.12.15/js/useCountdown-CsXUo9Cb.js>  
<http://10.28.12.15/js/useFileCell-DizVBE4N.js>  
[http://10.28.12.15/js/useForm-CU\\_npHFz.js](http://10.28.12.15/js/useForm-CU_npHFz.js)  
<http://10.28.12.15/js/useFormItem-JFxnwwJw.js>  
<http://10.28.12.15/js/useFormItemSingle-CO1VbhD0.js>  
<http://10.28.12.15/js/useIntersectionObserver-BN1Oujyu.js>  
<http://10.28.12.15/js/useThirdLogin-s4ln2YgK.js>  
<http://10.28.12.15/js/useTimeout-BVjGYMrE.js>  
<http://10.28.12.15/js/useWindowSizeFn-DVenrbuz.js>  
<http://10.28.12.15/js/vue-vendor-BAIZAQLp.js>  
<http://10.28.12.15/js/vxe-table-vendor-CwCnxkgz.js>  
[http://10.28.12.15/js/zh\\_CN-BjYh6ITC.js](http://10.28.12.15/js/zh_CN-BjYh6ITC.js)  
<http://10.28.12.15/login>  
<http://10.28.12.15/news/>  
<http://10.28.12.15/news/1903708880930369538>  
<http://10.28.12.15/resource/>  
<http://10.28.12.15/resource/img/>

<http://10.28.12.15/robots.txt>  
<http://10.28.12.15/xgszp-boot/>  
<http://10.28.12.15/xgszp-boot/swagger-resources>  
<http://10.28.12.15/xgszp-boot/swagger-resources/>  
<http://10.28.12.15/xgszp-boot/swagger-resources/configuration/>  
<http://10.28.12.15/xgszp-boot/swagger-resources/configuration/ui>  
<http://10.28.12.15/xgszp-boot/sys/>  
<http://10.28.12.15/xgszp-boot/sys/randomImage/>  
<http://10.28.12.15/xgszp-boot/sys/randomImage/1629428467008>  
<http://10.28.12.15/xgszp-boot/v2/>  
<http://10.28.12.15/xgszp-boot/v2/api-docs>  
<http://10.28.12.15/xgszp-boot/webjars/>  
<http://10.28.12.15/xgszp-boot/webjars/css/>  
<http://10.28.12.15/xgszp-boot/webjars/css/app.8a48e86b.css>  
<http://10.28.12.15/xgszp-boot/webjars/css/chunk-75464e7e.8fb93ba5.css>  
<http://10.28.12.15/xgszp-boot/webjars/css/chunk-d7d5f59c.a9ffbfcf.css>  
<http://10.28.12.15/xgszp-boot/webjars/css/chunk-vendors.f24a310a.css>  
<http://10.28.12.15/xgszp-boot/webjars/fonts/>  
<http://10.28.12.15/xgszp-boot/webjars/img/>  
<http://10.28.12.15/xgszp-boot/webjars/js/>  
<http://10.28.12.15/xgszp-boot/webjars/js/app.9fa057ee.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-069eb437.355c4fb0.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-0d102d5a.b2bddffc.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-0fd67716.d57e2c41.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-260d712a.390177fe.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-2d0af44e.392afcd6.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-2d0bd799.eb48b7f1.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-2d0da532.591ad7fc.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-3b888a65.8737ce4f.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-3ec4aaa8.a79d19f8.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-589faee0.5bfd1708.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-735c675c.5b409314.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-75464e7e.b130271b.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-adb9e944.2c7f24fe.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-d7d5f59c.e61130f3.js>  
<http://10.28.12.15/xgszp-boot/webjars/js/chunk-vendors.d51cf6f8.js>  
<http://10.28.12.15/xgszp-boot/xgsHome/>  
<http://10.28.12.15/xgszp-boot/xgsHome/xgsHome/>  
<http://10.28.12.15/xgszp-boot/xgsHome/xgsHome/listForHome>  
<http://10.28.12.15/xgszp-boot/xgsJournalism/>  
<http://10.28.12.15/xgszp-boot/xgsJournalism/xgsJournalism/>  
<http://10.28.12.15/xgszp-boot/xgsJournalism/xgsJournalism/list>  
<http://10.28.12.15/xgszp-boot/xgsJournalism/xgsJournalism/queryById>  
<http://10.28.12.15/xgszp-boot/xgsTalentpool/>  
<http://10.28.12.15/xgszp-boot/xgsTalentpool/xgsTalentpool/>  
<http://10.28.12.15/xgszp-boot/xgsTalentpool/xgsTalentpool/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/online/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/online/cgform/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/online/cgform/api/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/online/cgform/api/aigc>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/listMine>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsFavoriteJob/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/>



<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/checkApplyByPosId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/checkHasApplied>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/doPositionApply>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/getPositionApply>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/listMine>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/listMine>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositionApply2/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/apply>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/check>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/edit>  
[http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/first\\_text](http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/first_text)  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/getDeptList>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/getPageById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/post>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/positions/xgsPositions/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/getDepartRejectByApplyId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/getResumeData>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsFlowOpinions/submitByApplyId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsUserResumeFile/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsUserResumeFile/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsUserResumeFile/analysisResume>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsUserResumeFile/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsUserResumeFile/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsUserResumeFile/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsUserResumeFile/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/resume/xgsUserResumeFile/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/checkRule/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/checkRule/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/checkRule/checkByCode>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/checkRule/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/checkRule/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/checkRule/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/checkRule/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/checkRule/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/>



<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/addFile>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/addText>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/appAddFile>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/deleteOne>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/fileList>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/listByForm>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/comment/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dataSource/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dataSource/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dataSource/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dataSource/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dataSource/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dataSource/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dataSource/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dict/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dict/getDictItems/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dictItem/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/dictItem/dictItemCheck>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/duplicate/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/duplicate/check>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/fillRule/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/fillRule/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/fillRule/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/fillRule/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/fillRule/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/fillRule/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/fillRule/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/formFile/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/formFile/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/formFile/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/formFile/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/formFile/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/formFile/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/formFile/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/getQrcodeToken>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/login>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/phoneLogin>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/position/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/position/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/position/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/position/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/position/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/position/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/position/queryByCode>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/position/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/position/queryByIds>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/quartzJob/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/quartzJob/pause>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/quartzJob/resume>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/randomImage/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepart/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepart/listAll>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartPermission/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartPermission/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartPermission/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartPermission/deleteBatch>

<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartPermission/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartPermission/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartPermission/queryByld>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartRole/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartRole/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartRole/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartRole/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartRole/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartRole/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysDepartRole/queryByld>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysRoleIndex/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysRoleIndex/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysRoleIndex/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysRoleIndex/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysRoleIndex/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysRoleIndex/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysRoleIndex/queryByCode>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/sysRoleIndex/queryByld>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/tableWhiteList/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/tableWhiteList/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/tableWhiteList/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/tableWhiteList/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/tableWhiteList/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/sys/tableWhiteList/queryByld>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/xgsContactUs/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/xgsContactUs/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/xgsContactUs/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/xgsContactUs/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/xgsContactUs/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/xgsContactUs/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsContactUs/xgsContactUs/queryByld>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsExport/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsExport/exportResumeWord>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsExport/testTemplates>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/getCarousellImage>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/listForHome>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/queryByld>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsHome/xgsHome/syncHomeContent>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/xgsInterview/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/xgsInterview/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/xgsInterview/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/xgsInterview/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/xgsInterview/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/xgsInterview/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsInterview/xgsInterview/queryByld>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsIntroduce/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsIntroduce/xgsIntroduce/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsIntroduce/xgsIntroduce/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsIntroduce/xgsIntroduce/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsIntroduce/xgsIntroduce/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsIntroduce/xgsIntroduce/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsIntroduce/xgsIntroduce/list>

[illegible]

<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeBSH/queryXgsResumeResearchDirectionByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeBSH/queryXgsResumeResearchPaperByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeBSH/queryXgsResumeResearchResultByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeBSH/queryXgsResumeWorksByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/applyJob>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/queryXgsResumeEdusByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/queryXgsResumeHomeByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/queryXgsResumePositionDescriptionByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/queryXgsResumeResearchDirectionByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/queryXgsResumeResearchPaperByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/queryXgsResumeResearchResultByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeFG/queryXgsResumeWorksByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/applyJob>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/queryById>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/queryXgsResumeEdusByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/queryXgsResumeHomeByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/queryXgsResumePositionDescriptionByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/queryXgsResumeResearchDirectionByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/queryXgsResumeResearchPaperByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/queryXgsResumeResearchResultByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsResume/xgsResumeTJ/queryXgsResumeWorksByMainId>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/xgsTalentpool/>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/xgsTalentpool/add>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/xgsTalentpool/addBatchFromResume>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/xgsTalentpool/delete>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/xgsTalentpool/deleteBatch>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/xgsTalentpool/edit>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/xgsTalentpool/list>  
<http://10.28.12.15/xgszp-boot/xgszp-boot/xgsTalentpool/xgsTalentpool/queryById>



# Scan of 10.28.12.2:84

## Scan details

|                    |                                  |
|--------------------|----------------------------------|
| Scan information   |                                  |
| Start time         | 2026-03-13T10:23:28.192303+08:00 |
| Start url          | http://10.28.12.2:84             |
| Host               | 10.28.12.2:84                    |
| Scan time          | 4 minutes, 8 seconds             |
| Profile            | Full Scan                        |
| Server information | nginx/1.23.4                     |
| Responsive         | True                             |
| Server OS          | Unknown                          |
| Application build  | 24.10.241106172                  |

## Threat level

### Acunetix Threat Level 2

One or more medium-severity type vulnerabilities have been discovered by the scanner. You should investigate each of these vulnerabilities to ensure they will not escalate to more severe problems.

## Alerts distribution

|                                                                                                 |   |
|-------------------------------------------------------------------------------------------------|---|
| Total alerts found                                                                              | 4 |
|  Critical      | 0 |
|  High          | 0 |
|  Medium        | 2 |
|  Low           | 0 |
|  Informational | 2 |

Alerts summary

 Insecure HTTP Usage

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| Classification             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Changed<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-16                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

 SSL/TLS Not Implemented

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |           |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N<br>Base Score: 5.1<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: Low<br>Integrity Impact to the Vulnerable System: Low<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N<br>Base Score: 5.4<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Unchanged<br>Confidentiality Impact: Low<br>Integrity Impact: Low<br>Availability Impact: None                                                                                                                                                                                                                                           |           |
| CVSS2                      | Base Score: 5.8<br>Access Vector: Network_accessible<br>Access Complexity: Medium<br>Authentication: None<br>Confidentiality Impact: Partial<br>Integrity Impact: Partial<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined              |           |
| CWE                        | CWE-319                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | 1         |

 **Content Security Policy (CSP) Not Implemented**

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Changed<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-1021                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

 **Permissions-Policy header not implemented**

|                |
|----------------|
| Classification |
|----------------|



|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Changed<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-1021                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

Alerts details

 Insecure HTTP Usage

|                    |                              |
|--------------------|------------------------------|
| Severity           | Medium                       |
| Reported by module | /target/http_redirections.js |

Description

It was detected that your web application uses HTTP protocol, but doesn't automatically redirect users to HTTPS.

Impact

In some circumstances, it could be used for a man-in-the-middle (MitM) attack

Recommendation

It's recommended to implement best practices of HTTP Redirection into your web application. Consult web references for more information

References

[HTTP Redirections](https://infosec.mozilla.org/guidelines/web_security#http-redirections) ([https://infosec.mozilla.org/guidelines/web\\_security#http-redirections](https://infosec.mozilla.org/guidelines/web_security#http-redirections))

Affected items

| Web Server                                                                                                                  |
|-----------------------------------------------------------------------------------------------------------------------------|
| Details                                                                                                                     |
| Request headers                                                                                                             |
| GET / HTTP/1.1                                                                                                              |
| Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8                                                     |
| Accept-Encoding: gzip,deflate,br                                                                                            |
| User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 |
| Host: 10.28.12.2:84                                                                                                         |
| Connection: Keep-alive                                                                                                      |

 SSL/TLS Not Implemented

|                    |                  |
|--------------------|------------------|
| Severity           | Medium           |
| Reported by module | /RPA/no_https.js |

Description

This scan target was connected to over an unencrypted connection. A potential attacker can intercept and modify data sent and received from this site.

Impact

Possible information disclosure.

Recommendation

The site should send and receive data over a secure (HTTPS) connection.

References

[SSL/TLS Not Implemented | Invicti](https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/ssltls-not-implemented/) (<https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/ssltls-not-implemented/>).

Affected items

| Web Server                                                                                                                  |
|-----------------------------------------------------------------------------------------------------------------------------|
| Verified vulnerability                                                                                                      |
| Details                                                                                                                     |
| Request headers                                                                                                             |
| GET /api/blade-system/menu/lazy-list HTTP/1.1                                                                               |
| Host: 10.28.12.2:84                                                                                                         |
| accept: */*                                                                                                                 |
| accept-language: en-US                                                                                                      |
| Referer: http://10.28.12.2:84/login                                                                                         |
| Accept-Encoding: gzip, deflate, br                                                                                          |
| Connection: keep-alive                                                                                                      |
| User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 |

 Content Security Policy (CSP) Not Implemented

|                    |                                  |
|--------------------|----------------------------------|
| Severity           | Informational                    |
| Reported by module | /httpdata/CSP_not_implemented.js |

Description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks.

Content Security Policy (CSP) can be implemented by adding a **Content-Security-Policy** header. The value of this header is a string containing the policy directives describing your Content Security Policy. To implement CSP, you should define lists of allowed origins for the all of the types of resources that your site utilizes. For example, if you have a simple site that needs to load scripts, stylesheets, and images hosted locally, as well as from the jQuery library from their CDN, the CSP header could look like the following:

```
Content-Security-Policy:
  default-src 'self';
  script-src 'self' https://code.jquery.com;
```

It was detected that your web application doesn't implement Content Security Policy (CSP) as the CSP header is missing from the response. It's recommended to implement Content Security Policy (CSP) into your web application.

Impact

CSP can be used to prevent and/or mitigate attacks that involve content/code injection, such as cross-site scripting/XSS attacks, attacks that require embedding a malicious resource, attacks that involve malicious use of iframes, such as clickjacking attacks, and others.

Recommendation

It's recommended to implement Content Security Policy (CSP) into your web application. Configuring Content Security Policy involves adding the **Content-Security-Policy** HTTP header to a web page and giving it values to control resources the user agent is allowed to load for that page.

References

[Content Security Policy \(CSP\)](https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP) (<https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>)  
[Implementing Content Security Policy](https://hacks.mozilla.org/2016/02/implementing-content-security-policy/) (<https://hacks.mozilla.org/2016/02/implementing-content-security-policy/>)

Affected items

| Web Server |
|------------|
| Details    |

#### Paths without CSP header:

- <http://10.28.12.2:84/neq/find-password>
- <http://10.28.12.2:84/login>
- <http://10.28.12.2:84/>
- <http://10.28.12.2:84/neq/>
- <http://10.28.12.2:84/clientaccesspolicy.xml>
- <http://10.28.12.2:84/api.7z>
- <http://10.28.12.2:84/api.bak>
- <http://10.28.12.2:84/api.cfg>
- <http://10.28.12.2:84/api.csv>
- <http://10.28.12.2:84/api.dump>
- <http://10.28.12.2:84/api.ini>
- <http://10.28.12.2:84/api.jar>
- <http://10.28.12.2:84/api.old>
- <http://10.28.12.2:84/api.ost>
- <http://10.28.12.2:84/api.pst>
- <http://10.28.12.2:84/api.sh>
- <http://10.28.12.2:84/public/font/>
- <http://10.28.12.2:84/api.sln>
- <http://10.28.12.2:84/api.tar>
- <http://10.28.12.2:84/api.war>
- <http://10.28.12.2:84/api.zip>

#### Request headers

```
GET /neq/find-password HTTP/1.1

Referer: http://10.28.12.2:84/

authorization: Basic c2FiZXI6c2FiZXJfc2VjcmV0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.2:84

Connection: Keep-alive
```

 **Permissions-Policy header not implemented**

|                    |                                 |
|--------------------|---------------------------------|
| Severity           | Informational                   |
| Reported by module | /httpdata/permissions_policy.js |

**Description**

The Permissions-Policy header allows developers to selectively enable and disable use of various browser features and APIs.

**Impact**

**Recommendation**

**References**

[Permissions-Policy / Feature-Policy \(MDN\)](https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy) (https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy)  
[Permissions Policy \(W3C\)](https://www.w3.org/TR/permissions-policy-1/) (https://www.w3.org/TR/permissions-policy-1/)

**Affected items**

|                   |
|-------------------|
| <b>Web Server</b> |
| Details           |

#### Locations without Permissions-Policy header:

- <http://10.28.12.2:84/neq/find-password>
- <http://10.28.12.2:84/login>
- <http://10.28.12.2:84/>
- <http://10.28.12.2:84/neq/>
- <http://10.28.12.2:84/clientaccesspolicy.xml>
- <http://10.28.12.2:84/api.7z>
- <http://10.28.12.2:84/api.bak>
- <http://10.28.12.2:84/api.cfg>
- <http://10.28.12.2:84/api.csv>
- <http://10.28.12.2:84/api.dump>
- <http://10.28.12.2:84/api.ini>
- <http://10.28.12.2:84/api.jar>
- <http://10.28.12.2:84/api.old>
- <http://10.28.12.2:84/api.ost>
- <http://10.28.12.2:84/api.pst>
- <http://10.28.12.2:84/api.sh>
- <http://10.28.12.2:84/public/font/>
- <http://10.28.12.2:84/api.sln>
- <http://10.28.12.2:84/api.tar>
- <http://10.28.12.2:84/api.war>
- <http://10.28.12.2:84/api.zip>

#### Request headers

GET /neq/find-password HTTP/1.1

Referer: <http://10.28.12.2:84/>

authorization: Basic c2FiZXI6c2FiZXJfc2VjcmV0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.2:84

Connection: Keep-alive

## Scanned items (coverage report)

---

<http://10.28.12.2:84/>

<http://10.28.12.2:84/api.bak>

<http://10.28.12.2:84/api.cfg>

<http://10.28.12.2:84/api.csv>

<http://10.28.12.2:84/api.dump>

<http://10.28.12.2:84/api.ini>

<http://10.28.12.2:84/api.old>

<http://10.28.12.2:84/api.ost>

<http://10.28.12.2:84/api.pst>

<http://10.28.12.2:84/api.sh>

<http://10.28.12.2:84/api.sln>

<http://10.28.12.2:84/api.war>

<http://10.28.12.2:84/api/>

<http://10.28.12.2:84/api/blade-auth/>

<http://10.28.12.2:84/api/blade-auth/oauth/>

<http://10.28.12.2:84/api/blade-auth/oauth/captcha>

<http://10.28.12.2:84/api/blade-auth/oauth/logout>

<http://10.28.12.2:84/api/blade-system/>

<http://10.28.12.2:84/api/blade-system/dict/>

<http://10.28.12.2:84/api/blade-system/dict/dictionary>

<http://10.28.12.2:84/api/blade-system/dict/parent-list>

<http://10.28.12.2:84/api/blade-system/dict/remove>

<http://10.28.12.2:84/api/blade-system/dict/submit>

<http://10.28.12.2:84/api/blade-system/menu/>

<http://10.28.12.2:84/api/blade-system/menu/buttons>

<http://10.28.12.2:84/api/blade-system/menu/detail>

<http://10.28.12.2:84/api/blade-system/menu/lazy-list>

<http://10.28.12.2:84/api/blade-system/menu/remove>

<http://10.28.12.2:84/api/blade-system/menu/routes>

<http://10.28.12.2:84/api/blade-system/menu/submit>

<http://10.28.12.2:84/api/blade-system/menu/top-menu>

<http://10.28.12.2:84/assets/>

<http://10.28.12.2:84/assets/ele.3cd85772.js>

<http://10.28.12.2:84/assets/index.03884966.js>

<http://10.28.12.2:84/assets/index.42d80078.css>

<http://10.28.12.2:84/assets/index.4cdac31b.css>

<http://10.28.12.2:84/assets/index.72f6c00c.js>

<http://10.28.12.2:84/assets/index.99917928.css>

<http://10.28.12.2:84/assets/index.9d32a058.css>

<http://10.28.12.2:84/assets/index.c49e0869.js>

<http://10.28.12.2:84/assets/index.ca8a240c.js>

<http://10.28.12.2:84/assets/login-form.6d8e88dc.css>

<http://10.28.12.2:84/assets/login-form.9ab9359b.js>

<http://10.28.12.2:84/assets/login-header.14c228e5.js>

<http://10.28.12.2:84/assets/login-header.9b0d7efa.css>

<http://10.28.12.2:84/assets/logo.17fa9f84.js>

<http://10.28.12.2:84/assets/naq-layout.68980c3b.css>

<http://10.28.12.2:84/assets/naq-layout.aff93c2d.js>

<http://10.28.12.2:84/assets/page-layout.76735eeb.js>

<http://10.28.12.2:84/assets/vue.ddc2a4c2.js>

<http://10.28.12.2:84/clientaccesspolicy.xml>

<http://10.28.12.2:84/crossdomain.xml>

<http://10.28.12.2:84/login>

<http://10.28.12.2:84/neq/>

<http://10.28.12.2:84/neq/find-password>

<http://10.28.12.2:84/public/>

<http://10.28.12.2:84/public/font/>

<http://10.28.12.2:84/robots.txt>



# Scan of 10.28.12.2:85

## Scan details

|                    |                                  |
|--------------------|----------------------------------|
| Scan information   |                                  |
| Start time         | 2026-03-13T10:23:28.220887+08:00 |
| Start url          | http://10.28.12.2:85             |
| Host               | 10.28.12.2:85                    |
| Scan time          | 3 minutes, 58 seconds            |
| Profile            | Full Scan                        |
| Server information | nginx/1.23.4                     |
| Responsive         | True                             |
| Server OS          | Unknown                          |
| Application build  | 24.10.241106172                  |

## Threat level

### Acunetix Threat Level 2

One or more medium-severity type vulnerabilities have been discovered by the scanner. You should investigate each of these vulnerabilities to ensure they will not escalate to more severe problems.

## Alerts distribution

|                                                                                                 |   |
|-------------------------------------------------------------------------------------------------|---|
| Total alerts found                                                                              | 4 |
|  Critical      | 0 |
|  High          | 0 |
|  Medium        | 2 |
|  Low           | 0 |
|  Informational | 2 |

Alerts summary

 Insecure HTTP Usage

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| Classification             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Changed<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-16                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

 SSL/TLS Not Implemented

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |           |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N<br>Base Score: 5.1<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: Low<br>Integrity Impact to the Vulnerable System: Low<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N<br>Base Score: 5.4<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Unchanged<br>Confidentiality Impact: Low<br>Integrity Impact: Low<br>Availability Impact: None                                                                                                                                                                                                                                           |           |
| CVSS2                      | Base Score: 5.8<br>Access Vector: Network_accessible<br>Access Complexity: Medium<br>Authentication: None<br>Confidentiality Impact: Partial<br>Integrity Impact: Partial<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined              |           |
| CWE                        | CWE-319                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | 1         |

 **Content Security Policy (CSP) Not Implemented**

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Changed<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-1021                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

 **Permissions-Policy header not implemented**

|                |
|----------------|
| Classification |
|----------------|

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| CVSS4                      | CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Active<br>Confidentiality Impact to the Vulnerable System: None<br>Integrity Impact to the Vulnerable System: None<br>Availability Impact to the Vulnerable System: None<br>Confidentiality Impact to the Subsequent System: None<br>Integrity Impact to the Subsequent System: None<br>Availability Impact to the Subsequent System: None |           |
| CVSS3                      | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:N/A:N<br>Base Score: 0.0<br>Attack Vector: Network<br>Attack Complexity: Low<br>Privileges Required: None<br>User Interaction: Required<br>Scope: Changed<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None                                                                                                                                                                                                                                             |           |
| CVSS2                      | Base Score: 0.0<br>Access Vector: Network_accessible<br>Access Complexity: Low<br>Authentication: None<br>Confidentiality Impact: None<br>Integrity Impact: None<br>Availability Impact: None<br>Exploitability: Not_defined<br>Remediation Level: Not_defined<br>Report Confidence: Not_defined<br>Availability Requirement: Not_defined<br>Collateral Damage Potential: Not_defined<br>Confidentiality Requirement: Not_defined<br>Integrity Requirement: Not_defined<br>Target Distribution: Not_defined                         |           |
| CWE                        | CWE-1021                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |           |
| Affected items             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Variation |
| <a href="#">Web Server</a> |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | 1         |

Alerts details

 Insecure HTTP Usage

|                    |                              |
|--------------------|------------------------------|
| Severity           | Medium                       |
| Reported by module | /target/http_redirections.js |

Description

It was detected that your web application uses HTTP protocol, but doesn't automatically redirect users to HTTPS.

Impact

In some circumstances, it could be used for a man-in-the-middle (MitM) attack

Recommendation

It's recommended to implement best practices of HTTP Redirection into your web application. Consult web references for more information

References

[HTTP Redirections](https://infosec.mozilla.org/guidelines/web_security#http-redirections) ([https://infosec.mozilla.org/guidelines/web\\_security#http-redirections](https://infosec.mozilla.org/guidelines/web_security#http-redirections))

Affected items

| Web Server                                                                                                                  |
|-----------------------------------------------------------------------------------------------------------------------------|
| Details                                                                                                                     |
| Request headers                                                                                                             |
| GET / HTTP/1.1                                                                                                              |
| Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8                                                     |
| Accept-Encoding: gzip,deflate,br                                                                                            |
| User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 |
| Host: 10.28.12.2:85                                                                                                         |
| Connection: Keep-alive                                                                                                      |

 SSL/TLS Not Implemented

|                    |                  |
|--------------------|------------------|
| Severity           | Medium           |
| Reported by module | /RPA/no_https.js |

Description

This scan target was connected to over an unencrypted connection. A potential attacker can intercept and modify data sent and received from this site.

Impact

Possible information disclosure.

Recommendation

The site should send and receive data over a secure (HTTPS) connection.

References

[SSL/TLS Not Implemented | Invicti](https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/ssltls-not-implemented/) (https://www.invicti.com/web-vulnerability-scanner/vulnerabilities/ssltls-not-implemented/)

Affected items

| Web Server                                                                                                                  |
|-----------------------------------------------------------------------------------------------------------------------------|
| Verified vulnerability                                                                                                      |
| Details                                                                                                                     |
| Request headers                                                                                                             |
| POST /api/enroll/student/oauth/get-sms-captcha HTTP/1.1                                                                     |
| Host: 10.28.12.2:85                                                                                                         |
| Content-Length: 37                                                                                                          |
| accept: application/json, text/plain, */*                                                                                   |
| accept-language: en-US                                                                                                      |
| authorization: Basic c2FiZXI6c2FiZXJfc2VjcmV0                                                                               |
| content-type: application/json                                                                                              |
| origin: http://10.28.12.2:85                                                                                                |
| Referer: http://10.28.12.2:85/login                                                                                         |
| Accept-Encoding: gzip, deflate, br                                                                                          |
| Connection: keep-alive                                                                                                      |
| User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36 |
| {"studentEmail":"e","studentTel":"e"}                                                                                       |

 Content Security Policy (CSP) Not Implemented

|                    |                                  |
|--------------------|----------------------------------|
| Severity           | Informational                    |
| Reported by module | /httpdata/CSP_not_implemented.js |

Description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks.

Content Security Policy (CSP) can be implemented by adding a **Content-Security-Policy** header. The value of this header is a string containing the policy directives describing your Content Security Policy. To implement CSP, you should define lists of allowed origins for the all of the types of resources that your site utilizes. For example, if you have a simple site that needs to load scripts, stylesheets, and images hosted locally, as well as from the jQuery library from their CDN, the CSP header could look like the following:

```
Content-Security-Policy:
  default-src 'self';
  script-src 'self' https://code.jquery.com;
```

It was detected that your web application doesn't implement Content Security Policy (CSP) as the CSP header is missing from the response. It's recommended to implement Content Security Policy (CSP) into your web application.

Impact

CSP can be used to prevent and/or mitigate attacks that involve content/code injection, such as cross-site scripting/XSS attacks, attacks that require embedding a malicious resource, attacks that involve malicious use of iframes, such as clickjacking attacks, and others.

Recommendation

It's recommended to implement Content Security Policy (CSP) into your web application. Configuring Content Security Policy involves adding the **Content-Security-Policy** HTTP header to a web page and giving it values to control resources the user agent is allowed to load for that page.

References

[Content Security Policy \(CSP\)](https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP) (https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP)  
[Implementing Content Security Policy](https://hacks.mozilla.org/2016/02/implementing-content-security-policy/) (https://hacks.mozilla.org/2016/02/implementing-content-security-policy/)

Affected items

| Web Server |
|------------|
| Details    |



#### Paths without CSP header:

- <http://10.28.12.2:85/api.tar.bz2>
- <http://10.28.12.2:85/api.sql.bz2>
- <http://10.28.12.2:85/api.zip>
- <http://10.28.12.2:85/api.bz2>
- <http://10.28.12.2:85/api.war>
- <http://10.28.12.2:85/api.tar>
- <http://10.28.12.2:85/api.sln>
- <http://10.28.12.2:85/api.sh>
- <http://10.28.12.2:85/api.pst>
- <http://10.28.12.2:85/api.dump>
- <http://10.28.12.2:85/api.jar>
- <http://10.28.12.2:85/api.old>
- <http://10.28.12.2:85/api.ini>
- <http://10.28.12.2:85/api.ost>
- <http://10.28.12.2:85/api.csv>
- <http://10.28.12.2:85/api.cfg>
- <http://10.28.12.2:85/api.bak>
- <http://10.28.12.2:85/api.7z>
- <http://10.28.12.2:85/crossdomain.xml>
- <http://10.28.12.2:85/>
- <http://10.28.12.2:85/login>

#### Request headers

```
GET /api.tar.bz2 HTTP/1.1

Referer: http://10.28.12.2:85/api/

authorization: Basic c2FiZXI6c2FiZXJfc2VjcmV0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.2:85

Connection: Keep-alive
```

 **Permissions-Policy header not implemented**

|                    |                                 |
|--------------------|---------------------------------|
| Severity           | Informational                   |
| Reported by module | /httpdata/permissions_policy.js |

**Description**

The Permissions-Policy header allows developers to selectively enable and disable use of various browser features and APIs.

**Impact**

**Recommendation**

**References**

[Permissions-Policy / Feature-Policy \(MDN\)](https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy) (https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy)  
[Permissions Policy \(W3C\)](https://www.w3.org/TR/permissions-policy-1/) (https://www.w3.org/TR/permissions-policy-1/)

**Affected items**

|                   |
|-------------------|
| <b>Web Server</b> |
| Details           |

#### Locations without Permissions-Policy header:

- <http://10.28.12.2:85/api.tar.bz2>
- <http://10.28.12.2:85/api.sql.bz2>
- <http://10.28.12.2:85/api.zip>
- <http://10.28.12.2:85/api.war>
- <http://10.28.12.2:85/api.tar>
- <http://10.28.12.2:85/api.sln>
- <http://10.28.12.2:85/api.sh>
- <http://10.28.12.2:85/api.pst>
- <http://10.28.12.2:85/api.dump>
- <http://10.28.12.2:85/api.jar>
- <http://10.28.12.2:85/api.old>
- <http://10.28.12.2:85/api.ini>
- <http://10.28.12.2:85/api.ost>
- <http://10.28.12.2:85/api.csv>
- <http://10.28.12.2:85/api.cfg>
- <http://10.28.12.2:85/api.bak>
- <http://10.28.12.2:85/api.7z>
- <http://10.28.12.2:85/api.bz2>
- <http://10.28.12.2:85/crossdomain.xml>
- <http://10.28.12.2:85/assets/>
- <http://10.28.12.2:85/>

#### Request headers

GET /api.tar.bz2 HTTP/1.1

Referer: <http://10.28.12.2:85/api/>

authorization: Basic c2FiZXI6c2FiZXJfc2VjcmV0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8

Accept-Encoding: gzip,deflate,br

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36

Host: 10.28.12.2:85

Connection: Keep-alive

## Scanned items (coverage report)

---

<http://10.28.12.2:85/>

<http://10.28.12.2:85/api.bak>

<http://10.28.12.2:85/api.cfg>

<http://10.28.12.2:85/api.csv>

<http://10.28.12.2:85/api.dump>

<http://10.28.12.2:85/api.ini>

<http://10.28.12.2:85/api.old>

<http://10.28.12.2:85/api.ost>

<http://10.28.12.2:85/api.pst>

<http://10.28.12.2:85/api.sh>

<http://10.28.12.2:85/api.sln>

<http://10.28.12.2:85/api.war>

<http://10.28.12.2:85/api/>

<http://10.28.12.2:85/api/blade-auth/>

<http://10.28.12.2:85/api/blade-auth/oauth/>

<http://10.28.12.2:85/api/blade-auth/oauth/captcha>

<http://10.28.12.2:85/api/enroll/>

<http://10.28.12.2:85/api/enroll/student/>

<http://10.28.12.2:85/api/enroll/student/oauth/>

<http://10.28.12.2:85/api/enroll/student/oauth/get-sms-captcha>

<http://10.28.12.2:85/api/enroll/student/oauth/get-sms-captcha-forget>

<http://10.28.12.2:85/api/enroll/student/oauth/get-system-register-config>

<http://10.28.12.2:85/assets/>

<http://10.28.12.2:85/assets/index.763e8db0.css>

<http://10.28.12.2:85/assets/index.931178ce.css>

<http://10.28.12.2:85/assets/index.b7a6eb6d.js>

<http://10.28.12.2:85/assets/index.e3b44da6.js>

<http://10.28.12.2:85/clientaccesspolicy.xml>

<http://10.28.12.2:85/crossdomain.xml>

<http://10.28.12.2:85/login>

<http://10.28.12.2:85/robots.txt>